

■ DOCUMENT STRICTEMENT CONFIDENTIEL — NE PAS DIFFUSER AVANT LE 17/01/2025 08H00

UE INF-301 — Sécurité des réseaux — Session 1

Vendredi 17 janvier 2025 — 08h00–10h00 — Amphi A — Durée : 2 heures

Documents interdits · Calculatrice interdite · Téléphones éteints

Le barème indicatif est précisé pour chaque question. La clarté et la rigueur de l'argumentation sont valorisées. Répondre directement sur la copie double.

Partie I — QCM (6 points)

Q1 (1 pt) — Quelle est la politique par défaut recommandée par l'ANSSI pour les chaînes iptables ?

A. ACCEPT B. DROP C. REJECT D. LOG

Q2 (1 pt) — Quel port est utilisé par défaut par LDAP en clair ?

A. 389 B. 636 C. 443 D. 3306

Q3 (1 pt) — Quelle propriété cryptographique garantit que l'expéditeur ne peut pas nier avoir envoyé un message ?

A. Confidentialité B. Intégrité C. Non-répudiation D. Disponibilité

Q4 (1 pt) — Un firewall stateful se distingue d'un firewall stateless par :

A. Sa vitesse de traitement B. Sa table de suivi des connexions C. Son coût D. Sa couche OSI

Q5 (2 pts) — Parmi les vulnérabilités suivantes, lesquelles sont directement exploitables depuis le WiFi étudiant si celui-ci n'est pas cloisonné du réseau serveurs ? (2 réponses attendues)

A. Bind LDAP anonyme B. Injection SQL distante C. NFS sans authentification D. SMTP open relay

Partie II — Questions de cours (8 points)

Question 1 (3 pts)

Expliquez la différence entre un tunnel VPN PPTP et un tunnel WireGuard. Précisez les protocoles cryptographiques impliqués et les raisons pour lesquelles PPTP est considéré comme obsolète par l'ANSSI.

Question 2 (2 pts)

Qu'est-ce qu'un VLAN ? Expliquez en quoi la segmentation VLAN améliore la posture de sécurité d'un réseau d'établissement. Donnez un exemple de segmentation adaptée à une université accueillant étudiants, enseignants et serveurs sensibles.

Question 3 (3 pts)

Décrivez les étapes d'une attaque par escalade de privilèges sur un système Linux disposant de la directive `sudo NOPASSWD` dans `/etc/sudoers`. Quelles mesures préventives recommande le Guide d'hygiène ANSSI ?

Partie III — Étude de cas (6 points)

Un établissement universitaire dispose d'un réseau interne non segmenté (192.168.1.0/24) sur lequel coexistent : un serveur Moodle (HTTP/80), un serveur LDAP (389/TCP, bind anonyme), un

serveur de recherche NFS (2049/TCP), et des postes étudiants en WiFi. Un audit révèle les éléments suivants : aucun log centralisé, sudo NOPASSWD sur le poste administrateur, mots de passe hachés en SHA1 sans sel dans la base de données RH.

Q3.1 (3 pts) Identifiez les 5 vulnérabilités les plus critiques et classez-les par ordre de gravité en justifiant votre classement selon l'échelle ANSSI.

Q3.2 (3 pts) Proposez un plan de remédiation priorisé (court, moyen, long terme) en vous appuyant sur au moins 5 règles du Guide d'hygiène ANSSI citées dans le cours.